

Azure Compliance Implementation Checklist

Document:	sample_azure_compliance_document.txt
Frameworks:	ISO27018
Total Items:	4
Generated:	2025-11-12 19:44:31 UTC

Item #1: Implement Consent Management for PII Processing

Priority:

CRITICAL

Effort:

Complex

Description:

Establish a mechanism for obtaining, managing, and withdrawing consent for PII processing within the Azure environment. This is crucial for complying with data protection regulations like GDPR and ISO 27018.

Gap Addressed: Lack of explicit details on consent management for PII processing in the cloud environment.

Azure Portal Navigation: Azure Portal > Azure Active Directory > App registrations > [Your App] > API permissions

Settings to Configure:

Setting Name:	API permissions
Current Value:	Varies depending on existing configuration
Required Value:	Configure permissions to require explicit user consent for accessing PII data.
Location:	Azure Active Directory > App registrations > [Your App] > API permissions

Step-by-Step Implementation Guide:

Step 1: Navigate to Azure Portal > Azure Active Directory > App registrations

Click on 'Azure Active Directory' in the left navigation menu, then select 'App registrations'.

What to look for: You should see a list of registered applications.

Step 2: Select the application that processes PII.

Click on the name of the application that handles Personally Identifiable Information.

What to look for: You should see the overview page for the selected application.

Step 3: Go to API permissions

In the left menu, under 'Manage', click 'API permissions'.

What to look for: You should see a list of configured API permissions.

Step 4: Add required API permissions.

Click 'Add a permission'. Select the API (e.g., Microsoft Graph). Choose 'Delegated permissions' or

'Application permissions' as appropriate. Select the specific permissions related to PII (e.g., `User.Read`, `User.ReadBasic.All`, `User.ReadWrite`). Ensure 'Grant admin consent' is reviewed and granted if necessary.

What to look for: The selected permissions should appear in the list with a status indicating whether admin consent has been granted.

Step 5: Implement consent capture in your application.

Modify your application code to explicitly request user consent for accessing the configured API permissions. Use Azure AD's authentication libraries (MSAL) to handle the consent flow. Store consent records securely (e.g., in Azure Storage with encryption).

What to look for: Users should be prompted to grant consent when the application attempts to access PII data. Consent records should be stored securely.

Step 6: Implement consent withdrawal mechanism.

Provide a clear and easily accessible mechanism for users to withdraw their consent. This could be a button in the application or a link in their profile settings. Upon withdrawal, revoke the application's access to the user's PII and update the consent record.

What to look for: Users should be able to easily withdraw their consent. The application should no longer be able to access PII data after consent is withdrawn.

Verification Steps:

- Step 1: Test the application's consent flow by creating a new user and verifying that they are prompted to grant consent for accessing PII data.
- Step 2: Verify that consent records are stored securely in Azure Storage.
- Step 3: Test the consent withdrawal mechanism and confirm that the application's access to PII data is revoked after consent is withdrawn.
- Step 4: Audit logs in Azure Active Directory to confirm consent events are being recorded.

Azure Services Required: Azure Active Directory, Azure Logic Apps, Azure Storage

Expected Outcome: Establishes a clear and auditable consent management process for PII processing, ensuring compliance with data protection regulations.

Framework Reference: ISO 27018: 8.1.1, 8.1.2, 8.2.1

Additional Notes: Consider using Azure Logic Apps to automate consent management workflows, such as sending reminders to users to renew their consent periodically.

Item #2: Implement Data Subject Rights (DSR) Support

Priority:

CRITICAL

Effort:

Complex

Description:

Provide clear procedures and mechanisms for data subjects to exercise their rights (access, rectification, erasure, portability, objection) within the Azure cloud environment. This includes defining contact points and response times.

Gap Addressed: Insufficient information on how data subject rights (access, rectification, erasure, portability, objection) are specifically supported and implemented within the Azure cloud environment.

Azure Portal Navigation: Azure Portal > Azure Active Directory > Users > [User] > Profile

Settings to Configure:

Setting Name:	User Profile
Current Value:	Varies depending on existing user profiles
Required Value:	Ensure user profiles are complete and accurate. Implement a process for users to update their own pro
Location:	Azure Active Directory > Users > [User] > Profile

Step-by-Step Implementation Guide:

Step 1: Establish a dedicated DSR request intake process.

Create a clear and easily accessible channel for data subjects to submit DSR requests. This could be a dedicated email address (e.g., privacy@example.com), a web form, or a portal. Document the process clearly on your website and privacy policy.

What to look for: A clearly defined and documented DSR request intake process.

Step 2: Define roles and responsibilities for DSR handling.

Assign specific individuals or teams responsible for receiving, processing, and responding to DSR requests. Define clear roles and responsibilities for each stage of the process.

What to look for: A documented RACI matrix outlining roles and responsibilities for DSR handling.

Step 3: Implement procedures for verifying the identity of the data subject.

Establish a secure process for verifying the identity of the data subject making the request. This could involve multi-factor authentication, knowledge-based authentication, or other appropriate methods.

What to look for: A documented identity verification process for DSR requests.

Step 4: Implement procedures for processing DSR requests.

Develop specific procedures for each type of DSR request (access, rectification, erasure, portability, objection). These procedures should include steps for locating, retrieving, modifying, or deleting the requested data. Use Azure Purview to discover and classify PII data across your Azure environment.

What to look for: Documented procedures for each type of DSR request, including steps for data discovery, retrieval, modification, and deletion.

Step 5: Implement a secure mechanism for providing data to the data subject.

If providing data to the data subject (e.g., in response to an access or portability request), ensure that the data is transmitted securely. This could involve encryption, password protection, or other appropriate security measures. Consider using Azure Logic Apps to automate the DSR fulfillment process.

What to look for: A secure mechanism for transmitting data to data subjects.

Step 6: Document all DSR requests and responses.

Maintain a detailed record of all DSR requests received, the actions taken, and the responses provided.

This documentation should be stored securely and retained for the required retention period.
What to look for: A secure and auditable record of all DSR requests and responses.

Verification Steps:

- Step 1: Conduct regular audits of the DSR process to ensure compliance with data protection regulations.
- Step 2: Train employees on the DSR process and their responsibilities.
- Step 3: Test the DSR process by submitting sample requests and verifying that they are processed correctly.
- Step 4: Review and update the DSR process regularly to reflect changes in data protection regulations and best practices.

Azure Services Required: Azure Active Directory, Azure Logic Apps, Azure Storage, Azure Purview

Expected Outcome: Provides a comprehensive and compliant framework for handling data subject rights requests within the Azure cloud environment.

Framework Reference: ISO 27018: 8.2.2, 8.2.3, 8.2.4, 8.2.5

Additional Notes: Consider using a dedicated DSR management platform to streamline the DSR process and ensure compliance.

Item #3: Enhance Transparency Regarding Cryptography Usage

Priority:

HIGH

Effort:

Moderate

Description:

Provide clear information to cloud service customers about the circumstances in which cryptography is used to protect PII and the capabilities provided to assist the customer in applying their own cryptographic protection. This includes documenting encryption algorithms, key management practices, and available encryption options.

Gap Addressed: Missing details on transparency requirements, specifically how the cloud service customer is informed about the circumstances in which cryptography is used to protect PII and the capabilities provided to assist the customer in applying their own cryptographic protection.

Azure Portal Navigation: Azure Portal > Azure Key Vault > [Your Key Vault] > Keys

Settings to Configure:

Setting Name:	Key Vault Keys
Current Value:	Varies depending on existing key configurations
Required Value:	Ensure all encryption keys are securely stored and managed in Azure Key Vault.
Location:	Azure Key Vault > [Your Key Vault] > Keys

Document the key rotation process.

Step-by-Step Implementation Guide:

Step 1: Document the encryption methods used for PII at rest and in transit.

Create a comprehensive document outlining the encryption algorithms, key lengths, and key management practices used to protect PII data at rest (e.g., Azure Storage Service Encryption, Transparent Data Encryption) and in transit (e.g., TLS/SSL).
What to look for: A detailed document describing the encryption methods used for PII data.

Step 2: Document the key management practices.

Document how encryption keys are generated, stored, rotated, and revoked. Emphasize the use of Azure Key Vault for secure key management.
What to look for: A detailed document describing the key management practices, including the use of Azure Key Vault.

Step 3: Provide guidance on how customers can apply their own cryptographic protection.

Offer guidance and best practices on how customers can implement their own encryption solutions, such as using Azure Key Vault to manage their own encryption keys or using client-side encryption.
What to look for: A document providing guidance on how customers can apply their own cryptographic protection.

Step 4: Make the documentation readily available to customers.

Publish the documentation on a secure and easily accessible platform, such as a customer portal or a knowledge base.
What to look for: The documentation is readily available to customers.

Step 5: Regularly review and update the documentation.

Review and update the documentation regularly to reflect changes in encryption technologies, key management practices, and regulatory requirements.
What to look for: The documentation is regularly reviewed and updated.

Verification Steps:

- Step 1: Verify that the documentation is accurate and up-to-date.
- Step 2: Verify that the documentation is easily accessible to customers.
- Step 3: Verify that the documentation provides clear and concise information about cryptography usage.
- Step 4: Conduct regular audits to ensure compliance with transparency requirements.

Azure Services Required: Azure Key Vault, Azure Storage Service Encryption, Transparent Data Encryption (TDE), Azure Disk Encryption

Expected Outcome: Enhances transparency regarding cryptography usage, empowering customers to understand how their PII is protected and to implement their own cryptographic controls.

Framework Reference: ISO 27018: 9.1.1, 9.1.2, 9.1.3

Additional Notes: Consider providing training to customers on cryptography best practices and how to use Azure's encryption features.

Item #4: Enforce Secure Log-on Procedures for Cloud Service Users

Priority:

HIGH

Effort:

Moderate

Description:

Implement and enforce secure log-on procedures for all cloud service users under the customer's control, as per section 9.4.3 of ISO/IEC 27002. This includes enforcing strong passwords, multi-factor authentication (MFA), and account lockout policies.

Gap Addressed: No explicit mention of providing secure log-on procedures for cloud service users under the customer's control, as per section 9.4.3 of ISO/IEC 27002.

Azure Portal Navigation: Azure Portal > Azure Active Directory > Security > Conditional Access > Policies

Settings to Configure:

Setting Name:	Conditional Access Policies
Current Value:	Varies depending on existing policies
Required Value:	Enforce MFA for all users accessing the Azure environment. Implement account lockout policies to prevent brute-force attacks.
Location:	Azure Active Directory > Security > Conditional Access > Policies

Step-by-Step Implementation Guide:

Step 1: Enable Multi-Factor Authentication (MFA) for all users.

Navigate to Azure Portal > Azure Active Directory > Security > Conditional Access > Policies. Create a new policy that requires MFA for all users and all cloud apps. Configure the policy to apply to all users or specific groups as needed.

What to look for: The Conditional Access policy should be enabled and configured to require MFA for all users.

Step 2: Configure password policies.

Navigate to Azure Portal > Azure Active Directory > Security > Authentication methods > Password protection. Configure password complexity requirements (e.g., minimum length, character requirements) and password expiration policies.

What to look for: The password policies should be configured to enforce strong passwords.

Step 3: Implement account lockout policies.

Navigate to Azure Portal > Azure Active Directory > Security > Authentication methods > Password protection. Configure the account lockout policy to lock accounts after a certain number of failed login attempts.

What to look for: The account lockout policy should be configured to prevent brute-force attacks.

Step 4: Enable Azure AD Identity Protection.

Navigate to Azure Portal > Azure Active Directory > Security > Identity Protection. Enable the User risk policy and the Sign-in risk policy to automatically detect and respond to suspicious sign-in activity.

What to look for: Azure AD Identity Protection should be enabled and configured to detect and respond to risky sign-in activity.

Step 5: Educate users on secure log-on practices.

Provide training to users on the importance of strong passwords, MFA, and other secure log-on practices.

What to look for: Users are aware of and understand secure log-on practices.

Verification Steps:

- Step 1: Verify that MFA is required for all users when accessing the Azure environment.
- Step 2: Verify that password policies are enforced and that users are required to create strong passwords.
- Step 3: Verify that account lockout policies are in place and that accounts are locked after a certain number of failed login attempts.
- Step 4: Monitor Azure AD Identity Protection reports to identify and respond to risky sign-in activity.
- Step 5: Conduct regular audits to ensure compliance with secure log-on procedures.

Azure Services Required: Azure Active Directory, Azure Active Directory Conditional Access

Expected Outcome: Enforces secure log-on procedures for all cloud service users, reducing the risk of unauthorized access to PII data.

Framework Reference: ISO/IEC 27002: 9.4.3, ISO 27018: 9.2.1

Additional Notes: Consider using Azure AD Privileged Identity Management (PIM) to further restrict access to sensitive resources and require just-in-time access for privileged roles.